GUIDE ORAL DE SOUTENANCE

Ce qu'il faut dire sur chaque slide

Project Resilience-Alpha — script de présentation

16 slides · ~1 min 30 à 2 min par slide

Équipe Workshop2026-M2-G01 · EPSI/myDiL · Octobre 2026

Mode d'emploi

Pour chaque slide : un **bandeau** (titre, durée indicative, qui parle), le texte **à dire** (à adapter avec vos mots, surtout ne pas lire mot à mot), et parfois un **conseil** (■). Gardez un ton de conseil et de pilotage, pas de simple description technique.

Répartition suggérée (à adapter à votre équipe)

Rôle	Slides	Idéal pour le membre qui a porté…
Intro & contexte	1 – 4	la coordination / la gouvernance
Architecture & Dév	5 – 7	le SI de paiement et l'infra
IA (détection & RAG)	8 – 9	la partie Machine Learning
Remédiation & sécu	10 – 12	la cybersécurité et la reprise
Résultats & clôture	13 – 16	la synthèse / le pitch

Au niveau national, la première minute inclut une **introduction individuelle en anglais** : préparez une phrase chacun (nom, rôle sur le projet).

Minutage cible

- **Pitch + slides** : ~5 min. Ne vous attardez pas — la démo vaut plus que les diapositives.
- **Clip Chrono** : ~1 min (vidéo).
- **Démonstration en direct** : ~3 min. C'est l'axe le plus noté : gardez-y du temps.

Le script, slide par slide

SLIDE 1 — Titre

30 s · Intro

À dire : Bonjour, nous sommes l'équipe G01 et nous présentons Project Resilience-Alpha. Notre promesse : démontrer qu'un système de paiement critique peut encaisser un incident de sécurité et **se rétablir tout seul**, sans intervention humaine. Trois chiffres : 5 domaines intégrés, 13 services, une reprise en moins de 60 secondes.

■ *Annoncez l'énergie du projet. Introductions individuelles (en anglais pour la finale).*

SLIDE 2 — Le message

1 min · Intro

À dire : Aujourd'hui, quand un paiement tombe, un humain doit intervenir : c'est lent et non reproductible. Nous démontrons l'inverse, en trois temps : **détecter** l'anomalie par du machine learning, **décider et agir** avec un moteur de remédiation, et surtout **vérifier** que le métier remarche vraiment.

■ *C'est le fil rouge de toute la soutenance. Insistez sur le point 3 : vérifier, pas juste redémarrer.*

SLIDE 3 — Contexte & enjeux

1 min · Intro

À dire : Posons le problème métier. Une plateforme de paiement en panne, ce sont des partenaires bloqués, des clients qui perdent confiance, et chaque minute coûte — avec en plus des exigences réglementaires fortes dans la finance. Notre mission : prouver, sur un périmètre maîtrisé, qu'une reprise automatique peut être conçue, observée et vérifiée. Tout est fictif, aucune donnée bancaire réelle.

■ *Le coût de l'arrêt justifie tout l'investissement technique. Commencez métier, pas techno.*

SLIDE 4 — Les 5 domaines

1 min · Intro

À dire : Le sujet impose cinq domaines, et nous les avons **intégrés** dans une seule plateforme cohérente : Développement, Infrastructure, IA/Data, Cybersécurité et Gouvernance. Ce ne sont pas cinq projets côte à côte, mais une chaîne qui fonctionne ensemble.

■ *Chaque membre peut nommer ici le domaine qu'il a porté.*

SLIDE 5 — Architecture

1 min 30 · Archi

À dire : Voici le flux. L'attaquant frappe le WAF, notre portier unique. Le WAF protège l'API de paiement et l'authentification, devant la base — qui n'est jamais exposée. Prometheus et Loki observent tout. La détection ML lit les métriques et alerte le moteur de remédiation, qui agit sur les conteneurs. Le dashboard rend le tout visible. Message clé : **un seul service exposé**, surface d'attaque minimale.

■ *Suivez les flèches à l'écran pendant que vous parlez.*

SLIDE 6 — Développement

1 min 30 · Archi

À dire : Le cœur métier est une API FastAPI qui exécute de vraies transactions atomiques, protégée par un service d'authentification JWT, au-dessus d'une base PostgreSQL. La vitrine et le dashboard sont en React/Tailwind. La preuve que ça marche : une transaction fictive aboutit avec le statut « settled ».

■ *Montrez le JSON « settled » : c'est l'état sain AVANT l'incident, indispensable pour prouver la reprise APRÈS.*

SLIDE 7 — Infrastructure

1 min 30 · Archi

À dire : Deux volets. Le déploiement reproductible : Docker Compose orchestre les 13 conteneurs, Ansible automatise les opérations. Et l'observabilité : Prometheus pour les métriques, Grafana pour les graphiques et alertes, Loki pour les journaux. Cette chaîne n'est pas décorative : **c'est elle qui alimente la détection par IA**.

■ *Faites le lien explicite : les métriques Prometheus sont les yeux de notre modèle ML.*

SLIDE 8 — Détection ML

2 min · IA

À dire : Pas de règles codées en dur — le sujet l'interdit, et c'est fragile. On apprend à un modèle la « forme » du comportement normal sur 4 indicateurs, et on signale tout écart. On utilise une covariance robuste qui mesure la distance au nuage normal ; le seuil est calibré automatiquement, pas écrit à la main. Analogie : on encercle une journée normale, tout ce qui en sort est suspect.

■ *Si on vous challenge : on a d'abord testé un Isolation Forest, moins fiable sur les écarts extrêmes ; on a changé et validé par tests.*

SLIDE 9 — Assistant RAG

1 min · IA

À dire : Deuxième brique d'IA : un assistant local (Ollama + LangChain) qui aide l'opérateur à retrouver l'info dans les procédures. Il cherche d'abord les bons passages, puis rédige en citant ses sources. Point crucial : il est en **lecture seule**, sans aucun pouvoir d'action — il aide à comprendre, il n'agit jamais.

■ *Insistez sur la séparation des pouvoirs : l'assistant n'est pas le moteur de remédiation.*

SLIDE 10 — Remédiation

2 min · Remédiation

À dire : C'est le cœur du sujet. Le moteur ferme la boucle : détection, décision selon l'anomalie, action, puis **vérification réelle**. Une reprise n'est déclarée que si la base est lisible ET qu'une nouvelle transaction fictive aboutit — un conteneur qui redémarre ne suffit pas. Et comme ce moteur a des droits élevés, on le bride : liste fermée d'actions, pas de shell distant, tout est journalisé.

■ *C'est l'axe le plus noté. Deux messages : vérification réelle + composant privilégié maîtrisé.*

SLIDE 11 — Cybersécurité

1 min 30 · Sécurité

À dire : Notre sécurité est une défense en profondeur, plusieurs barrières : le WAF filtre et limite en entrée ; les conteneurs sont durcis (non-root, droits réduits) ; les journaux sont centralisés dans un SIEM pour l'investigation ; les secrets sont chiffrés avec SOPS, jamais en clair. Et toute action offensive reste strictement limitée à notre labo.

■ *Rappelez le cadre éthique : jamais le réseau du campus ni des tiers.*

SLIDE 12 — Scénarios d'attaque

1 min · Sécurité

À dire : Nous avons deux scénarios complémentaires. A : un déni de service volumétrique via le WAF, pour montrer la défense périmétrique. B : une attaque qui franchit le périmètre et frappe l'API directement, pour déclencher la détection et la remédiation. Deux histoires : le WAF bloque, et quand une attaque passe, l'IA prend le relais.

■ *Enchaînez vers la démo live juste après les résultats.*

SLIDE 13 — Résultats mesurés

1 min 30 · Synthèse

À dire : Voici les chiffres réels de notre démo. Scénario A : sur 30 secondes, le WAF a bloqué **97 %** du flood — le backend n'a presque pas bougé. Et pour la reprise : un RTO sous 60 secondes sans humain, un RPO proche de zéro, et tous les services sains après reprise, transaction re-jouée. On rend visible l'état avant, pendant et après l'incident.

■ *Ce sont VOS chiffres (10 486 bloquées sur 10 820). Assumez-les avec fierté.*

SLIDE 14 — Gouvernance

1 min 30 · Synthèse

À dire : La résilience n'est pas que technique. Nous avons mené une analyse de risques EBIOS RM, rédigé un PCA/PRA adapté, et lu les enjeux NIS2/DORA en distinguant ce qu'un prototype de 4 jours démontre de ce qu'il ne peut qu'esquisser. C'est une démarche de conseil : quels arbitrages, quelles recommandations à une direction.

■ *Posture senior : vous savez ce qui est critique, ce que ça coûte, et vous êtes honnêtes sur les limites réglementaires.*

SLIDE 15 — Limites

1 min · Synthèse

À dire : Soyons honnêtes sur nos arbitrages : SOPS plutôt que Vault dynamique, pas de mTLS interne, un PC Hôte unique, un modèle entraîné sur des observations constituées faute d'historique. Ce que nous revendiquons : non pas une plateforme industrielle, mais une chaîne de cyber-résilience **crédible, exécutée, testée et défendable**.

■ *Annoncer ses limites est une force. Terminez sur ce que vous revendiquez.*

SLIDE 16 — Conclusion

30 s · Synthèse

À dire : Pour résumer : un système de paiement critique qui encaisse un incident et se rétablit seul. Détection par ML, remédiation vérifiée par une vraie transaction, défense en profondeur avec 97 % du flood bloqué, et une gouvernance honnête. Merci — place à la démonstration en direct.

■ *Enchaînez IMMÉDIATEMENT sur la démo. Une démo qui tourne vaut mieux que des diapositives.*

Préparer les 5 minutes d'échange avec le jury

Répartissez-vous les thèmes. Réponses courtes, assumées. Les questions les plus probables :

Q. Pourquoi ce modèle ML et pas un autre ?

R. Détecteur de nouveauté à covariance robuste : fiable sur les écarts extrêmes, seuil calibré sur les données, validé par tests. L'Isolation Forest testé avant ratait certains cas.

Q. Un redémarrage, est-ce une vraie reprise ?

R. Non : on vérifie la santé profonde ET une transaction fictive aboutie, sinon on relance (max 3).

Q. Le moteur de remédiation, risque de sécurité ?

R. Droits élevés mais bridés : liste fermée d'actions, pas de shell distant, journalisation, jeton limité.

Q. Le WAF a bloqué mais la détection n'a rien vu ?

R. Normal sur le scénario A : le WAF a trop bien filtré, le backend n'a pas été stressé. Le scénario B montre l'autre cas.

Q. Prêt pour la production ?

R. Non, prototype de 4 jours, limites documentées. On revendique une chaîne crédible, exécutée, testée, défendable.

Q. Et la conformité NIS2/DORA concrètement ?

R. On démontre gestion du risque, détection et tests de résilience ; la notification réglementaire d'incident, elle, ne se démontre pas en prototype — on le dit honnêtement.

Project Resilience-Alpha — Guide oral · Équipe Workshop2026-M2-G01 · EPSI/myDiL, Octobre 2026.